

King Fahad University of Petroleum and Minerals

SWE445: Secure Software Development

Group Project

Phase#1 Requirements Specifications

Term 252

Section#1

Group# 4

Name	ID
HAYTHAM HAMDAN	202182690
ISMAEL ARQSOSI	202182150
SAUD ALSHUSHAN	202152750
ZYAD ALYAHYA	202039560
SAUD MAASHI	202016560
ABDULAZIZ ALQAHTANI	201857220

❖Part A: List Secure Software Requirements

The following is a listed secure software requirement for the CIA AAA principles. Each has 5 related requirements. The requirements are categorized for 2 parts, functional requirements and non-functional requirements.

Legend:

ID	Meaning
AUTH	Authentication
AUTHZ	Authorization
INT	Integrity
AUD	Accountability
CONF	Confidentiality
AVL	Availability

1. Functional Security Requirements

ID	Requirement	Description
AUTH-01	User Login	The system shall require all users (patients, doctors, administrators, and insurance providers) to log in using a unique username and password.
AUTH-02	Multi-Factor Authentication	The system shall require doctors and administrators to use multi-factor authentication when accessing sensitive medical records.
AUTHZ-01	Role Based Access	The system shall use role-based access control (RBAC) so that each user can only access features based on their role.
AUTHZ-02	Doctor Record Access	The system shall allow doctors to access only the medical records of patients assigned to them.
AUTHZ-03	Patient Record Viewing	The system shall allow patients to view their medical records but not modify them.
AUTHZ-04	Admin Permissions	The system shall restrict administrative functions such as user management and database control to administrators only.
AUTHZ-05	Patient Consent	The system shall require patient approval before sharing medical records with other healthcare providers.

ID	Requirement	Description
INT-01	Record Update Control	The system shall allow only authorized healthcare professionals to update patient medical records.
INT-02	Record Versioning	The system shall maintain a history of medical record changes for tracking updates.
AUD-01	Activity Logging	The system shall record user activities such as login attempts, record access, and record updates.

2. Non-Functional Security Requirements

ID	Requirement	Description
AUTH-03	Password Policy	The system shall enforce strong password policies including minimum length and complexity.
AUTH-04	Account Lock	The system shall lock accounts after several failed login attempts to prevent brute force attacks.
AUTH-05	Secure Password Storage	The system shall store passwords securely using hashing and salting techniques.
CONF-01	Data Encryption	The system shall encrypt sensitive patient data stored in the database.
CONF-02	Secure Communication	The system shall use HTTPS to protect data transmitted between users and the system.
CONF-03	Data Privacy	The system shall prevent unauthorized users from viewing patient medical records.
CONF-04	Data Masking	The system shall hide sensitive information such as passwords and insurance numbers in the interface.
CONF-05	Session Termination	The system shall automatically log out users after 15 minutes of inactivity to prevent unauthorized access to an unattended terminal.
INT-03	Input Validation	The system shall validate user input to prevent malicious attacks such as SQL injection.

ID	Requirement	Description
INT-04	Data Integrity Monitoring	The system shall detect unauthorized changes in stored patient data.
INT-05	Digital Signatures for Prescriptions	The system shall require a digital signature for all issued prescriptions to ensure they cannot be tampered with after being sent to the pharmacy.
AVL-01	System Availability	The system shall allow authorized users to access the system 24/7 except during maintenance.
AVL-02	Data Backup	The system shall maintain regular backups to prevent data loss.
AVL-03	DoS Protection	The system shall implement mechanisms to detect and mitigate denial-of-service attacks.
AVL-04	System Recovery	The system shall provide recovery procedures to restore services after failures.
AVL-05	Performance Monitoring	The system shall monitor system performance and notify administrators about system issues.
AUD-02	Access Tracking	The system shall record the identity of users accessing patient records.
AUD-03	Timestamp Logging	The system shall timestamp all system transactions.
AUD-04	Log Review	The system shall allow administrators to review logs for suspicious activity.
AUD-05	Security Alerts	The system shall notify administrators when suspicious behavior or repeated failed logins occur.

❖Part B: Use Case and Misuse Case

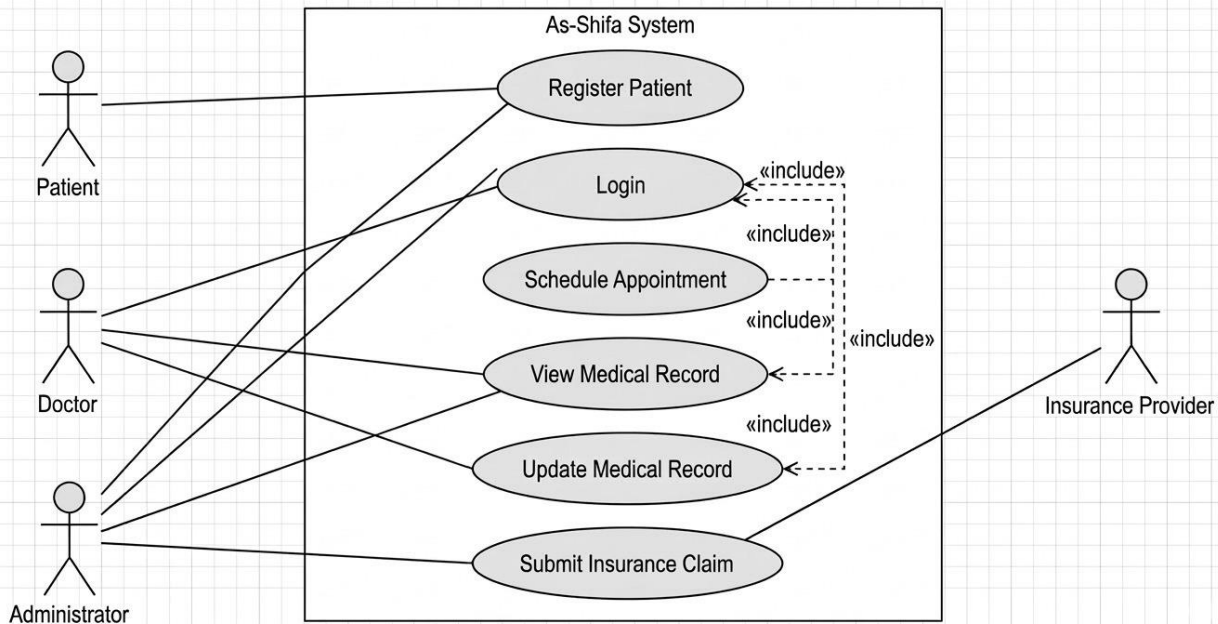
B.1 (Use Case Details and Diagram)

Actor	Description
Patient	A person who uses the system to manage appointments and view their medical information.
Doctor	A healthcare professional who accesses and updates patient medical records.
Administrator	A system manager responsible for maintaining user accounts and system operations.
Insurance Provider	An external entity that processes insurance claims and verifies insurance information.

Use Case ID	Use Case Name	Description
UC-01	Register Patient	Allows a patient to create an account in the healthcare system.
UC-02	Login	Allows users (patient, doctor, admin) to securely access the system.
UC-03	Schedule Appointment	Allows patients to schedule appointments with doctors.
UC-04	View Medical Record	Allows authorized users to view patient medical history.
UC-05	Update Medical Record	Allows doctors to update patient medical information after consultations.
UC-06	Submit Insurance Claim	Allows the system or admin to submit insurance claims to insurance providers.

Use case diagram:

As-Shifa Secure Healthcare Management System Use Case Diagram



B.2: (Use Case Description)

UC-01: Register Patient	
Description:	Allows a new patient to create an account in the As-Shifa Secure Healthcare Management System so they can access services such as appointment scheduling and viewing medical records.
Actors:	Patient
Main Flow:	1. Patient selects Register on the system interface. 2. System prompts the patient to enter required information (name, email, username, password, insurance information). 3. Patient enters the information. 4. System validates the input to prevent malicious data (INT-03 Input Validation). 5. System checks that the username or email is not already registered. 6. System verifies password strength according to password policy (AUTH-03 Password Policy). 7. System securely stores the patient credentials using hashing and salting (AUTH-05 Secure Password Storage). 8. System creates the patient account successfully. 9. System logs the account creation event (AUD-01 Activity Logging).
Alternative(s):	A1: If the username or email already exists, the system prompts the patient to choose another. A2: If the password does not meet security requirements, the system asks the patient to create a stronger password.

	A3: If invalid input is detected, the system rejects the data and asks the user to re-enter correct information.
--	---

UC-02: Login	
Description:	Allows authorized users (patient, doctor, administrator) to authenticate and securely access the healthcare system.
Actors:	Patient, Doctor, Administrator
Main Flow:	1. User opens the system login page. 2. User enters username and password. 3. System verifies credentials against stored records (AUTH-01 User Login). 4. System applies password hashing verification (AUTH-05 Secure Password Storage). 5. If the user is a doctor or administrator, the system requests multi-factor authentication (AUTH-02 MFA). 6. System validates the authentication factors. 7. System grants access according to the user's role (AUTHZ-01 Role Based Access Control). 8. System records the login event (AUD-01 Activity Logging, AUD-03 Timestamp Logging).
Alternative(s):	A1: If credentials are incorrect, the system denies access and records the attempt. A2: If multiple login attempts fail, the system locks the account (AUTH-04 Account Lock). A3: If MFA verification fails, the system denies access.

UC-03: Schedule Appointment	
Description:	Allows patients to schedule an appointment with a doctor through the system.
Actors:	Patient
Main Flow:	1. Patient logs into the system. 2. Patient selects Schedule Appointment. 3. System displays available doctors and appointment slots. 4. Patient selects a doctor and a preferred time slot. 5. System checks doctor availability. 6. System confirms the appointment and stores it in the database. 7. System logs the transaction (AUD-01 Activity Logging, AUD-03 Timestamp Logging). 8. Patient receives confirmation of the appointment.

Alternative(s):	A1: If the selected time slot is unavailable, the system prompts the patient to choose another time. A2: If the system detects invalid input, it rejects the request (INT-03 Input Validation). A3: If the system is unavailable due to maintenance, the appointment cannot be scheduled (AVL-01 System Availability).
-----------------	--

UC-04: View Medical Record	
Description:	Allows authorized users to view patient medical records securely.
Actors:	Patient, Doctor, Administrator
Main Flow:	1. User logs into the system. 2. User selects View Medical Record. 3. System verifies that the user has permission to access the record (AUTHZ-01 Role Based Access Control). 4. If the user is a doctor, the system verifies that the patient is assigned to that doctor (AUTHZ-02 Doctor Record Access). 5. System retrieves encrypted patient medical records from the database (CONF-01 Data Encryption). 6. System displays the medical records securely. 7. System logs the access event (AUD-02 Access Tracking, AUD-03 Timestamp Logging).
Alternative(s):	A1: If the user does not have permission to view the record, the system denies access (CONF-03 Data Privacy). A2: If the record cannot be retrieved due to system issues, the system informs the user.

UC-05: Update Medical Record	
Description:	Allows doctors to update patient medical information after a consultation.
Actors:	Doctor
Main Flow:	1. Doctor logs into the system. 2. Doctor selects a patient's medical record. 3. System verifies that the doctor is authorized to modify the record (AUTHZ-02 Doctor Record Access). 4. Doctor enters updated medical information. 5. System validates the input (INT-03 Input Validation). 6. System updates the medical record in the database (INT-01 Record Update Control). 7. System stores the previous record version for tracking (INT-02 Record Versioning).

	8. System logs the update activity (AUD-01 Activity Logging, AUD-03 Timestamp Logging).
Alternative(s):	A1: If the doctor is not authorized to update the record, the system denies the action. A2: If the input data is invalid, the system asks the doctor to correct the information.

UC-06: Submit Insurance Claim	
Description:	Allows the system or administrator to submit insurance claims to an insurance provider for patient treatments.
Actors:	Administrator, Insurance Provider
Main Flow:	1. Administrator logs into the system. 2. Administrator selects Submit Insurance Claim. 3. System retrieves relevant patient treatment information. 4. System verifies that the patient has valid insurance coverage. 5. System prepares the insurance claim request. 6. System securely sends the claim to the insurance provider using encrypted communication (CONF-02 Secure Communication). 7. Insurance provider receives and processes the claim. 8. System records the transaction and logs the event (AUD-01 Activity Logging, AUD-03 Timestamp Logging).
Alternative(s):	A1: If the insurance information is invalid or missing, the system rejects the claim submission. A2: If the communication with the insurance provider fails, the system retries or alerts the administrator. A3: If the system detects suspicious data modification, it prevents the submission (INT-04 Data Integrity Monitoring).

B.3: (Misuse Case Details and Diagram)

Misuse Actor	Description
Attacker	An external malicious user who attempts to gain unauthorized access to the system and sensitive patient data.
Malicious	An internal user (such as a staff member) who abuses their legitimate access to manipulate or misuse system data.

Misuse Actor	Description
Insider	

Misuse Case ID	Misuse Case Name	Description
MUC-01	Steal Login Credentials	An attacker attempts to obtain valid user login credentials in order to gain unauthorized access to the system.
MUC-02	Access Medical Records Illegally	An attacker attempts to view confidential patient medical records without proper authorization.
MUC-03	Modify Medical Records	A malicious insider attempts to alter patient medical records without proper authorization.
MUC-04	Submit Fake Insurance Claim	An attacker attempts to submit fraudulent insurance claims to receive unauthorized financial benefits.

Note: the misuse case is provided below with part C (mitigation + Misuse case) together

❖ Part C: Misuse Case Relationships with System Use Cases (Mitigation Diagram + Misuse Case)

These misuse cases **threaten** the system use cases.

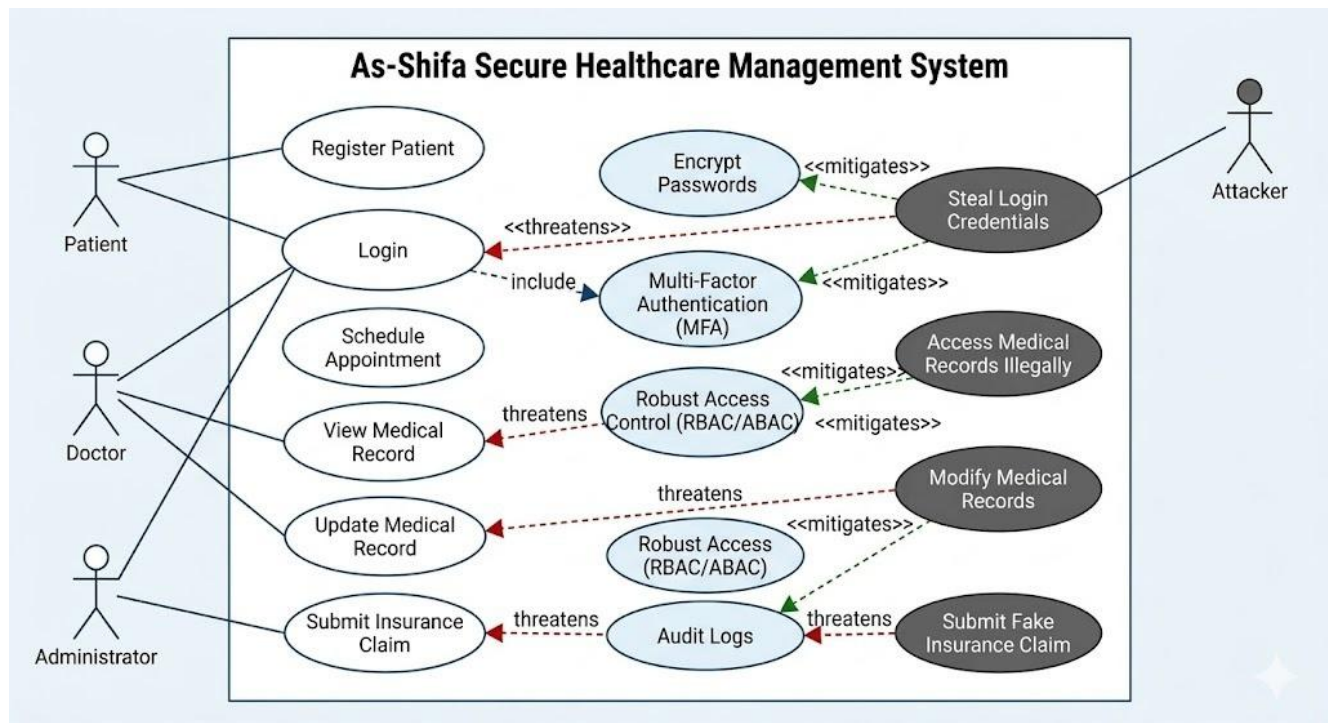
Misuse Case	Threatens
Steal Login Credentials	Login
Access Medical Records Illegally	View Medical Record
Modify Medical Records	Update Medical Record
Submit Fake Insurance Claim	Submit Insurance Claim

C.2: Mitigation Use Cases

Security controls are added to mitigate the misuse cases.

Mitigation Use Case	Mitigates
Encrypt Passwords	Steal Login Credentials
Multi-Factor Authentication	Steal Login Credentials
Access Control	Access Medical Records Illegally
Audit Logs	Modify Medical Records
Audit Logs	Submit Fake Insurance Claim

Mitigation + Misuse Case Diagram



Part D: Misuse Case descriptions

MUC-01: Steal Login Credentials	
Description:	An attacker attempts to obtain valid user login credentials (username and password) in order to gain unauthorized access to the healthcare system.
Actors:	Attacker
Main Flow:	1. The attacker targets a user account. 2. The attacker attempts to steal login credentials through phishing, malware, or brute-force attacks. 3. The attacker obtains valid credentials. 4. The attacker logs into the system using the stolen credentials. 5. The attacker gains unauthorized access to system resources.
Alternative(s):	• The system detects repeated failed login attempts and blocks the attacker. • The system prompts additional verification steps.
Mitigation Points	• Encrypt Passwords • Multi-Factor Authentication (MFA)

MUC-02: Access Medical Records Illegally	
Description:	An attacker attempts to access confidential patient medical records without proper authorization.
Actors:	Attacker
Main Flow:	1. The attacker gains access to the system through compromised credentials or vulnerabilities. 2. The attacker attempts to view patient medical records. 3. The system processes the request. 4. The attacker accesses sensitive patient medical data.
Alternative(s):	• The system denies access if the attacker lacks proper permissions. • Suspicious activity is detected and logged
Mitigation Points	• Access Control

MUC-03: Modify Medical Records

Description:	A malicious insider attempts to alter patient medical records without authorization, potentially causing incorrect medical information to be stored.
Actors:	Malicious Insider
Main Flow:	1. The malicious insider logs into the system using valid credentials. 2. The insider accesses patient medical records. 3. The insider modifies medical record information. 4. The modified data is saved in the system.
Alternative(s):	• The system detects abnormal record changes. • The system logs the activity for administrative review.
Mitigation Points	• Audit Logs

MUC-04: Submit Fake Insurance Claim	
Description:	An attacker attempts to submit fraudulent insurance claims in order to receive unauthorized financial benefits.
Actors:	Attacker Malicious Insider
Main Flow:	1. The attacker accesses the insurance claim submission function. 2. The attacker enters false medical treatment or billing information. 3. The system processes the insurance claim. 4. The fraudulent claim is submitted to the insurance provider.
Alternative(s):	• The system verifies claim information with patient records. • Suspicious claims are flagged for review.
Mitigation Points	• Audit Logs • Access Control